隐盾安全智能体 · 正式答辩演讲稿（演练版）

> 配套 PPT：`隐盾安全智能体汇报.pptx`（11 页，沿用原稿版式；P8 为控制端，创新点拆两页） 版本：V3.6.21 · 2026-10-26 用法：**每页先看“目标秒数”，再念“口播”，括号里是动作**。总口播约 4 分 40 秒，留 20 秒缓冲。 详细时间表、超时删减、问答见 正式答辩_5分钟_讲稿.md；18 题问答见 预答辩_3分钟_答辩准备.md。

练习前先记住 5 句话

1. **脱敏不是模型**：本地正则粗筛 + 程序化精验，不调用任何模型。
2. **小模型只做建议**：意图/风险插件是可选建议，不参与放行。
3. **云端只看占位符**：映射表不进模型上下文，回答回本机才还原。
4. **exe 不含模型权重**：模型走本机 Ollama，2B/4B 量化 CPU 可跑。
5. **审计是可发现，不是不可写**：能重写整台机器的人超出防护目标。

第 1 页 · 封面（目标 10 秒）

口播

> 各位评委好，我们的项目是隐盾安全智能体——面向数据隐私安全的 AI 协同办公桌面智能体。

动作：不要念团队成员和目录；说完停 1 秒，翻页。

忘词兜底：隐盾安全智能体，让 AI 看得见任务，看不见隐私。

第 2 页 · ① 作品简介（目标 30–33 秒）

口播

> 出发点很直接：涉密办公要用 AI，但敏感原文不能出本机。风险在四个环节：发给 AI 时出网、存到电脑里留副本、历史记录越积越多、AI 动手时未经确认。我们对应四道本地控制：入口脱敏、脱敏日志加加密存储、会话加密加审计、审批加权限。右边是分工：数据先过隐盾内核，模型只收到占位符，回答回本机还原；框架做判定，模型只做推理。

动作：先点左边四张卡，再沿右侧架构图走一遍——数据 → 内核 → 模型 → 本机还原；强调“框架做判定、模型只推理”。

忘词兜底：敏感原文不出本机，模型只看见占位符。

如果评委现在插问“AI 怎么脱敏”：

> 脱敏不用模型，是本地规则：正则粗筛 + 程序化精验；模型只负责后面的推理。

第 3 页 • ② 功能总览（目标 30–33 秒）

口播

> 先总后分：上面三组能力回答“能做什么”——对话与资料、文件操作与审计、统一后台；下面四个目标回答“做到什么程度”——可用，本机 2B/4B 量化模型 CPU 可跑；不可见，已识别实体出网明文 0 例；可审计，工具、审批、还原全部留痕；可部署，提供标准安装包，也保留免安装单文件方便试用。

动作：先点“一、三组能力”，横着带过三张卡；再点“二、四个目标”，手指四个绿色色块。

忘词兜底：三组能力，四个目标：可用、不可见、可审计、可部署。

第 4 页 • ② 关键功能：脱敏对话（目标 45–47 秒）

口播

> 先看脱敏对话。用户输入的是姓名、手机号、身份证这些真值；发送前，本地规则先做正则粗筛，再用程序化校验器精验——手机号看位数，银行卡过 Luhn，身份证看 18 位形状与出生日期，带分隔符的形态再过校验位；人名看姓氏表和触发词窗口。**这一步不调用任何模型。** 模型真正收到的是占位符；回答回来，本机再把占位符换回真值。映射表加密、不进模型上下文，所以模型服务方拿到的只是一段占位符文本。对已经识别出来的实体，出网明文是 0 例。

动作：先指左侧「用户看到 / 模型看到」两条；再指右侧真实客户端截图；最后指下面的审计预览。

忘词兜底：识别靠规则，还原在本机；模型全程只看见占位符。

如果评委问“能不能识别工作秘密”：

> 可以扩展：自定义敏感词表（字面词 + 正则）、自定义姓名/通讯录、行业词表插件；项目代号、客户名单、内部术语都能加。

第 5 页 • ③ 三层立体判断：先用途，再意图，最后操作风险（目标 43 秒）

口播

> 三层立体判断：先看用途，再看意图，最后看操作风险。第一层是用途红线，内核确定性规则，在模型和工具之前执行：收集个人信息去出售或牟利，直接拒绝；外发或公开，顶部红色警示。第二层是意图预判，回答想干什么、涉及什么数据、去哪、什么用途，模型只能加重不能减轻。第三层是操作风险，laya 按本机、局域网、正则三级给高/中/低危，并标明来源，只评动作本身。三层都只是建议，放行由人决定。

动作：指弹窗顶部红条 → 右侧① → ② → ③；最后指底部红字“是否相符不再发言”。

忘词兜底：先判用途，再判操作，最后才放行；判定权在人，不在模型。

如果评委问“为什么有的弹窗没有‘是否相符’”：

> 用途触线时故意不发言，避免用“相符”给危险请求背书；没有触线时会正常给相符/存疑/不符。

第 6 页 • ③ 审计黑匣子：每次使用都留痕（目标 35 秒）

口播

> 审计的重点不是“不可写”，而是每次使用都留痕。每次打开面板都会重新校验 HMAC 链和锚点，徽标不是缓存；现场可以直接点一次盾牌图标验证。每条工具调用、隐私检测、审批决策都在链上；审计里只存脱敏预览。改中间、尾部截断、降级改写、删锚点这些手法都能被发现——可发现是底线；能重写整台机器的人我们挡不住，这一点如实说明。

动作：如果现场演示，点左侧盾牌图标「审计黑匣子」，指绿色徽标；**不要点“重建锚点”**。

忘词兜底：重点是每次使用都留痕；可发现是底线。

第 7 页 • ③ 万物皆插件（目标 25 秒）

口播

> 万物皆插件：能力可以通过插件增加。laya 按本机、局域网、正则三级，每级标明来源，只做建议；插件只有建议型和增强型能力，判定类钩子永久禁止——能力可以加，判定权不外包。

动作：三列各点一下，不展开细节。

忘词兜底：万物皆插件；能力可以加，判定权不外包。

第 8 页 • ③ 控制端（目标 20 秒）

口播

> 控制端不是新的能力，而是把端点已经落盘的掩码事件集中起来看。它看到的和端点本地审计一样：掩码态、链头、元数据，拿不到真值，也不代理模型流量。控制面已具备三角色 RBAC、默认限速和一键 TLS；策略只能收紧：敏感路径取并集、审批下限取更严，豁免/放行/白名单不在通路里。

动作：四张卡片各点一下——态势总览 → 事件台账 → 策略下发 → 统计分析。

忘词兜底：控制端只汇总掩码事件，策略只能收紧。

第 9 页 • ④ 创新（一）：网关与用途（目标 22 秒）

口播

> 第一个创新是内存级脱敏网关：入口处完成替换，真值只在本机内存，模型上下文只有占位符；对已识别实体，出网明文 0 例。第二个是先判用途再判操作：用途触线时直接拒绝，不调用模型，也不给审批放行机会。

动作：指左、右两段 GIF，各停 1 秒。

忘词兜底：网关让模型看不见真值；用途红线在模型之前拒绝。

第 10 页 • ④ 创新（二）：分级与知识库（目标 22 秒）

口播

> 第三个是 laya 决策模型：它是近一个月才火起来的决策模型，我们第一时间接进项目，用它判断动作危不危险；本机优先、局域网次之、正则兜底，只做建议、不参与放行。第四个是脱敏知识库：入库即逐块脱敏，向量库只存占位符，检索结果标注片段不是全文。场景先做律所、医院、制造和政府外包；边界也如实说，留出集 281/296（94.9%），是经验值。

动作：指 laya 设置页与知识库检索 GIF；最后落到右下“边界”。

忘词兜底：laya 第一时间适配；知识库入库即脱敏。

第 11 页 • 结尾（目标 5 秒）

口播

> 隐私保护不该是使用约定，而应是架构约束。谢谢各位评委。

动作：说完停住，不要补“我们还有很多不足”；等评委提问。

一页速记（只看这 9 句）

1. 各位评委好，我们的项目是隐盾安全智能体。
2. 涉密办公要用 AI，但敏感原文不出本机；四个环节对应四道本地控制。
3. 三组能力，四个目标：可用、不可见、可审计、可部署。
4. 脱敏靠正则和精验，不调用模型；模型只看见占位符。
5. 先判用途，再判操作，最后才放行；判定权在人。
6. 审计重点是每次使用都留痕；可发现是底线。
7. 万物皆插件：能力可以加，判定权不外包。
8. 控制端只汇总掩码事件，策略只能收紧。
9. 隐私保护不该是使用约定，而应是架构约束。

数字只记这 5 个

数字	说法
0 例	对已识别实体，出网明文 0 例
281/296	留出集完整脱敏；首跑 222/280，修复后同留出集复测 281/296
30 类	敏感实体类型
7 个	内置插件；判定类钩子永久禁止
39 个	测试/评测套件

> 不说“100%”“绝对安全”“全覆盖”；数字带分母，边界一起说。

练习方法（三天）

第 1 天：顺稿，不掐表

- 朗读 3 遍，每页读完在纸上标一个“换气点”；

- 把每页第一句背下来（第一句决定你会不会卡住）；
- 不要求快，先做到“不看稿也能说出每页的一句话结论”。

第 2 天：掐表，只看关键词

- 用手机计时，目标 **4:45–4:52**；
- 每页只写 3 个关键词在便签上，逼自己组织句子；
- 记录到第 4 / 6 / 8 / 10 页的时间；第 11 页必须在 **4:47** 前开始。

第 3 天：全真彩排

- 站着讲，拿翻页笔，穿答辩当天衣服；
- 让队友在任意一页打断一次，练“停住—回答—接回原页”；
- 录一遍视频，回看三件事：有没有超时、有没有低头念稿、有没有说“然后/就是”。

超时砍单（从后往前）

1. **P8 控制端的展开**：只留“控制面只上报掩码事件，策略只能收紧”。
2. **P3 四个目标**：只留四个词，不解释。
3. **P6 六种删改**：只说“改中间、尾部截断、降级改写都能发现”。
4. **P4 规则细节**：只留“正则粗筛 + 程序化精验，不调用模型”。
5. **绝不砍**：P5 三层判断、P4“规则不是模型”、P9/P10 四个创新。

现场禁语

- ❌ “我们的本地小模型做脱敏”——改成“本地规则做脱敏，模型只做推理”。
- ❌ “安装包里带了 4B 模型”——改成“exe 不含权重，模型走本机 Ollama”。
- ❌ “召回 100% / 绝对安全 / 全覆盖”——带分母、说边界。
- ❌ “控制面可以直接上生产”——说“已具备三角色 RBAC / 默认限速 / 一键 TLS；多租户与证书轮换仍需生产化”。

答辩问答

18 题 + 5 道压力题见 预答辩_3分钟_答辩准备.md。优先背：

1. 和 DLP / Presidio 的区别；
2. 识别漏了怎么办；
3. 还原环节会不会成为后门；
4. 审计密钥在本机，能不能重写；
5. 小模型能力 / laya 只有 5/8；
6. 插件会不会破坏安全；
7. 用户一路点允许，审批还有没有意义；
8. 控制面能不能上生产。